
Informe de Pentesting

Actividad A08 — Hacking Ético

Ciente: **INSECUR S.A.** — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información

Licenciatura en Sistemas de Información — Facultad de Informática y Diseño

Docente: Ing. Rodrigo Atilio Elgueta

Alumna: **Chiara Hernandez**

Username de TryHackMe: **chiarahernandezp**

[Índice](#)

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Chiara Hernandez
DNI	45967321
Username TryHackMe	chiarahernandezp
Email institucional	hernandezchiara@uch.edu
Sala de elección (Nivel 2)	[COMPLETAR]
Branch en GitHub	hernandez-chiara
Fecha de inicio	2026-10-01
Fecha de cierre	2026-10-8

2. Pre-pentesting

Alcance del trabajo

El alcance de este trabajo se limita exclusivamente a los entornos de laboratorio provistos por la plataforma TryHackMe (TryHackMe.com), concretamente a las máquinas virtuales asignadas dentro de las salas *Pentesting Fundamentals*, *Basic Pentesting* y la sala de elección de Nivel 2. Dentro del alcance se incluyen los servicios expuestos por dichas máquinas (puertos TCP/UDP, servicios web, SMB, SSH, etc.) accedidos a través de la red VPN de TryHackMe. Quedan fuera de alcance: cualquier sistema, red o dispositivo que no pertenezca a la infraestructura de laboratorio de TryHackMe, incluyendo redes propias, de la facultad o de terceros.

Reglas de Enfrentamiento (ROE)

- Las pruebas se realizan únicamente contra la IP asignada dinámicamente por TryHackMe al desplegar cada máquina de laboratorio.
- Está prohibido aplicar las técnicas aprendidas contra sistemas reales o productivos fuera del entorno de laboratorio.
- No se realizan ataques de denegación de servicio (DoS) ni pruebas que puedan degradar la disponibilidad del servicio de TryHackMe para otros usuarios.
- Toda la actividad se documenta en bitácora (comandos ejecutados) y evidencias (capturas de pantalla), conforme a los mecanismos de control de autenticidad de la cátedra.
- Las flags y contraseñas obtenidas no se publican en texto plano en el repositorio; se reportan mediante su hash SHA-256 (ver Anexo C).
- Horario de trabajo: sin restricción horaria específica, dado que el entorno es un laboratorio aislado sin impacto en sistemas productivos de terceros.

Autorización

Declaro que cuento con autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (Docente: Ing. Rodrigo Atilio Elgueta) para realizar las actividades de hacking ético descritas en este informe, en el marco de la Actividad A08, exclusivamente sobre los entornos de laboratorio de TryHackMe indicados en la guía de la actividad.

Metodología utilizada

Se adoptó como referencia metodológica el flujo de trabajo propuesto por la guía de la cátedra, alineado con las fases descritas en **NIST SP 800-115** (*Technical Guide to Information Security Testing and Assessment*): Planeamiento (Pre-engagement), Descubrimiento (Reconocimiento y Escaneo), Ataque (Explotación y Post-explotación) y Reporte. Se eligió este marco por ser una guía técnica de referencia pública, ampliamente utilizada en pentesting profesional, que ordena claramente las fases sin exigir certificación previa, a diferencia de metodologías como OSSTMM. Para la fase de reconocimiento y escaneo se utilizó además el enfoque de enumeración de servicios de OWASP Testing Guide en lo referido a servicios web.

3. Durante: Hallazgos por fase

Campo	Valor
ID del hallazgo	H-01
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Post-explotación
Descripción	Dentro del home del usuario <code>kay</code> en la máquina de la sala Basic Pentesting, el archivo de clave privada SSH <code>~/.ssh/id_rsa</code> tenía permisos <code>-rw-r--r--</code> (644), es decir, legible por cualquier usuario del sistema, no solo por su propietario. Esto permitió, estando autenticada como el usuario <code>jan</code> , copiar la clave privada de <code>kay</code> sin necesidad de privilegios de root. Posteriormente, la <i>passphrase</i> que protegía la clave se obtuvo mediante ataque de diccionario offline (John the Ripper + rockyou.txt), permitiendo autenticarse como <code>kay</code> vía SSH sin conocer su contraseña de sistema.
Componente afectado	Permisos de archivo <code>/home/kay/.ssh/id_rsa</code>
Categoría (OWASP / CWE)	CWE-276 (Incorrect Default Permissions)
CVE (si aplica)	N/A (error de configuración local, no vulnerabilidad de software)
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	<code>ls -la /home/kay/.ssh</code> (permisos 644 en <code>id_rsa</code>); <code>ssh2john --wordlist=rockyou.txt</code> + <code>john</code> (passphrase crackeada); ver <code>bitacora/clase-basic-pentesting-04-10.txt</code> y <code>evidencias/explotacion/</code> .

Campo	Valor
Herramienta utilizada	OpenSSH client, ssh2john, John the Ripper
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Restringir permisos de toda clave privada a 600 (lectura/escritura solo para el propietario); auditar periódicamente permisos en directorios <code>~/.ssh</code> de todos los usuarios; proteger claves privadas con passphrases robustas que sigan la política de contraseñas de la organización.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Campo	Valor
ID del hallazgo	H-02
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	Una vez autenticada como el usuario kay (obtenido en H-01), se verificaron sus privilegios con <code>sudo -l</code> . La configuración de <code>sudoers</code> permite a kay ejecutar cualquier comando como cualquier usuario, incluyendo root, sin restricciones ((ALL : ALL) ALL). Esto implica que comprometer la cuenta de kay equivale a obtener control total del servidor (por ejemplo, mediante <code>sudo su</code> o <code>sudo bash</code>).
Componente afectado	Configuración <code>/etc/sudoers</code> para el usuario kay
Categoría (OWASP / CWE)	CWE-250 (Execution with Unnecessary Privileges)
CVE (si aplica)	N/A (error de configuración/política de privilegios)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	<code>sudo -l</code> ejecutado como kay , salida: <code>User kay may run the following commands on ip-10-66-142-44: (ALL : ALL) ALL;</code> ver <code>bitacora/clase_basic-pentesting_04-10.txt</code> .
Herramienta utilizada	<code>sudo</code> (comando nativo del sistema)
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Aplicar el principio de mínimo privilegio: otorgar a kay permisos de <code>sudo</code> únicamente sobre los comandos estrictamente necesarios para sus tareas, en lugar de acceso irrestricto (ALL:ALL). Revisar periódicamente el archivo <code>/etc/sudoers</code> y los grupos con privilegios administrativos.

Campo	Valor
Riesgo residual tras aplicar	☐ Bajo ☒ Medio ☐ Alto

4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	1	H-02
Alto	1	H-01
Medio		
Bajo		
Total	2	

5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

1. Corregir permisos de `/home/kay/.ssh/id_rsa` a 600 (prioridad alta, asociado a H-01).
2. Revisar y corregir la entrada de `/etc/sudoers` para `kay`, reemplazando `ALL:ALL` por los comandos mínimos necesarios (prioridad crítica, asociado a H-02).
3. Deshabilitar el directorio `/development/` del servidor web, o restringir su acceso, dado que exponía notas internas con información sensible (nombres de usuario, menciones a versiones de software).
4. Eliminar o proteger el share SMB `Anonymous`, que permitía acceso sin autenticación y filtró el archivo `staff.txt` con nombres de usuarios internos.

Recomendaciones administrativas (políticas y procesos)

1. Implementar una política de contraseñas robusta y verificar su cumplimiento (se detectó que la contraseña de `jan` era débil y cayó ante un diccionario común).
2. Capacitar al personal sobre el uso correcto de claves SSH: generación con passphrase robusta y permisos restrictivos por defecto.
3. Establecer revisiones periódicas (auditorías internas) de la configuración de `sudoers` y de los shares de red disponibles.
4. Concientizar al personal sobre no dejar notas internas con credenciales, nombres de usuario o información sensible en recursos accesibles sin autenticación (web, SMB).

6. Protocolo de contingencia

Escenario de falla

El escenario de falla se centra en el hallazgo H-02: si un atacante externo logra comprometer la cuenta del usuario **kay** (por ejemplo, reutilizando el vector de H-01), obtiene de inmediato privilegios root sobre el servidor completo mediante **sudo**. Esto podría derivar en la caída total del servicio (borrado o modificación de archivos críticos del sistema), instalación de malware o ransomware, o uso del servidor como pivote hacia otros sistemas de la red interna de INSECUR S.A.

Impacto sobre la continuidad del negocio

Si el servidor comprometido aloja servicios de cara al cliente (web, archivos compartidos vía Samba), su indisponibilidad afectaría directamente la operatoria de INSECUR S.A.: caída del sitio web corporativo, pérdida de acceso a archivos compartidos del equipo de desarrollo, y posible filtración de información interna (como la expuesta en `/development/` y en el share **Anonymous**). El tiempo de afectación dependería de si existen backups actualizados y de la rapidez de detección del incidente; en ausencia de monitoreo activo, el compromiso podría pasar desapercibido durante días.

Plan de respuesta

1. **Activación:** Detección mediante alertas de accesos SSH no habituales, cambios inesperados en archivos del sistema, o reporte de indisponibilidad del servicio por parte de usuarios/clientes.
2. **Contención:** Aislar el servidor de la red (desconectar o bloquear tráfico a nivel de firewall), revocar y rotar inmediatamente las claves SSH y contraseñas de todos los usuarios del sistema, en particular la de **kay**.
3. **Recuperación:** Restaurar el servicio desde el último backup íntegro verificado previo al incidente; reinstalar el sistema desde una imagen limpia si se confirma presencia de malware o persistencia del atacante.
4. **Comunicación:** Notificar de inmediato al responsable de sistemas/CTO de INSECUR S.A.; informar a clientes afectados si hubo exposición de datos; evaluar obligación de notificación a autoridades según la normativa de protección de datos vigente.
5. **Post-mortem:** Documentar la cronología del incidente, causa raíz (en este caso, permisos incorrectos en `id_rsa` y política de `sudoers` permisiva), y actualizar el plan de contingencia y las políticas de hardening en base a lo aprendido.

RTO y RPO estimados

RTO (Recovery Time Objective): [COMPLETAR: estimar según criticidad real del servicio para INSECUR S.A., p. ej. 4 horas]

RPO (Recovery Point Objective): [COMPLETAR: estimar según frecuencia de backups disponible, p. ej. 24 horas]

7. Anexos

Anexo A — Bitácora de comandos

Archivos bitacora/clase_XX_*.txt incluidos en el branch.

Anexo B — Capturas de pantalla

Carpeta evidencias/ con subcarpetas por fase. Cada archivo nombrado como <fase>_<hallazgoID>.png.

Anexo C — Hashes de las flags obtenidas

```
# Formato: identificador sha256_hash
Pentesting-Fundamentals (respuesta final)
583f30ba446f9f74d509726d25956b4b75ad965f953feffc996f6ad1382dc8d6

Basic Pentesting - contraseña de jan (hydra)
9eb6835cc95b053818b660bd9fc9f092a0b30cef89c1f0f17f469d5caa0ae617

Basic Pentesting - passphrase clave privada de kay
873504f0103a88d762191a358f4aa432dbbcf8af64f19dd913d7f8f925191a08

Basic Pentesting - contraseña final (pass.bak de kay)
3ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf57

[COMPLETAR: agregar hashes de flags de la sala de elección (Nivel 2)
una vez resuelta]
```

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma del estudiante

Fecha

8. Fuentes y bibliografía

- TryHackMe. *Pentesting Fundamentals*: [sala oficial](#)
- TryHackMe. *Basic Pentesting*: [sala oficial](#)
- OWASP Foundation. *Web Security Testing Guide (WSTG)*: [sitio oficial](#)
- NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.